RASTRO

Trazabilidad verificable de envíos sobre servicios gestionados en la nube

Cloud Computing (ISD38) · Grupo 30112 · Periodo 2026B

Docente: Daniel Alejandro García Rodríguez

Sergio Alejandro Montoya Granados
Nicolás Torres Perdomo
Óscar Julián Rincón Bejarano

Corporación Unificada Nacional de Educación Superior — CUN
Ingeniería de Sistemas · Bogotá, D. C.

`github.com/Serann10255/Rastro`

9 / 9 requisitos cumplidos, cada uno con su prueba automatizada

327 pruebas superadas, 5 omitidas y 0 fallos (6/11/2026)

8 · 3 funciones Lambda y tablas DynamoDB en AWS us-east-1

10 / 11 controles conformes en una auditoría independiente

1 Problema

En una mensajería urbana pequeña, el estado de un envío vive repartido entre:

- la memoria del mensajero
- un chat
- una hoja de cálculo
- el teléfono del despachador

Nadie puede decir quién cambió el estado, cuándo y con qué respaldo.

¿Cómo registrar de forma verificable cada cambio de estado, con su responsable y su evidencia, sobre servicios gestionados en la nube y con los permisos y el presupuesto de un entorno educativo?

2 Objetivo y método

Objetivo general. Desarrollar sobre servicios gestionados de AWS un sistema que registre de forma verificable el ciclo de vida de cada envío, con acceso por rol, aislamiento entre organizaciones y evidencia de entrega cifrada.

Objetivos específicos: **los cuatro cumplidos**

- ✓ Caracterizar el proceso actual
- ✓ Diseñar arquitectura y datos
- ✓ Construir y desplegar en AWS
- ✓ Verificar controles con pruebas

Método

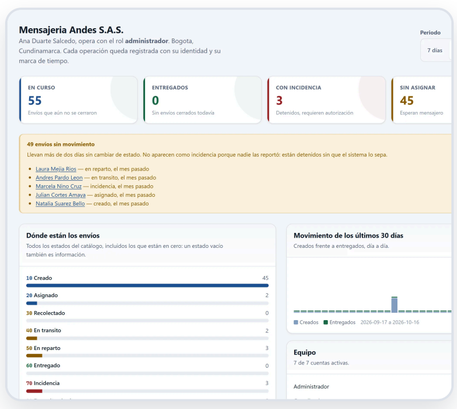
Iterativo e incremental, 12 semanas en 4 fases. Regla: **ningún requisito se dio por cumplido sin su prueba automatizada**. Y una auditoría independiente, porque quien despliega no concluye que su control funciona.

3 Solución

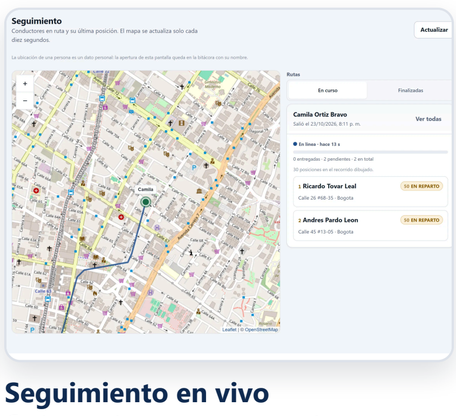
Cada cambio de estado queda **atribuido, fechado y validado**:

- **Máquina de estados** — Nueve estados; una transición no permitida se rechaza y queda registrada.
- **Bitácora encadenada por hash** — Actor, acción, recurso y momento; un verificador recalcula la cadena.
- **Evidencia cifrada** — Foto por enlace prefirmado, en S3 con llave KMS propia. Sin evidencia no hay ENTREGADO.
- **Aislamiento entre empresas** — Sin la organización la consulta ni se construye; entre empresas, 404 y no 403.
- **Roles y separación de funciones** — Ningún rol combina escritura con lectura de la bitácora.
- **Rutas con ubicación en vivo** — Solo mientras la ruta está abierta; el destinatario la ve sin cuenta.

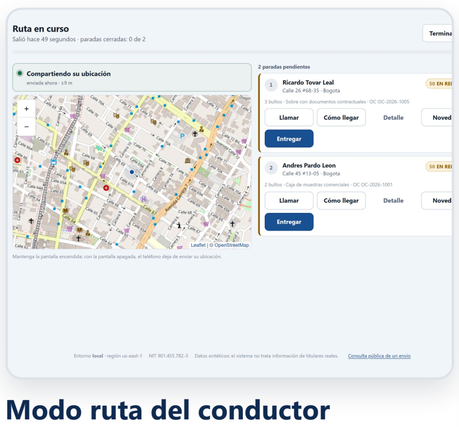
4 Funcionalidades, en la aplicación real



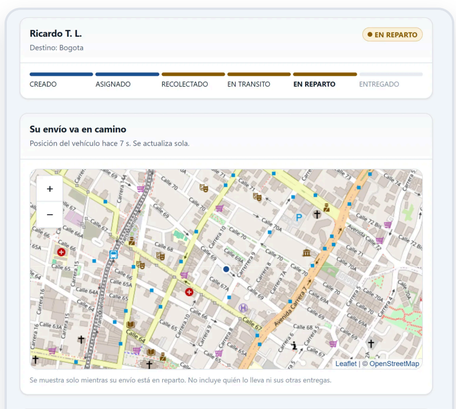
Panel de la organización
En curso, entregados, con incidencia y sin asignar, y los envíos sin movimiento.



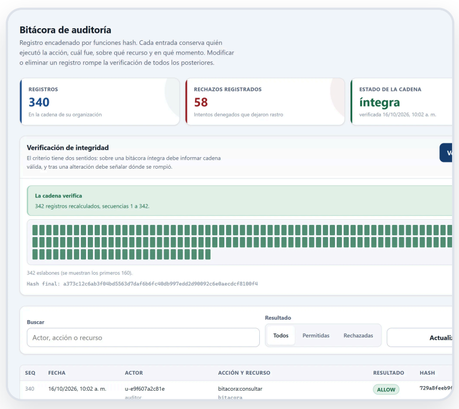
Seguimiento en vivo
Cada conductor en ruta en el mapa, con su recorrido y sus paradas.



Modo ruta del conductor
Comparte su ubicación solo con la ruta abierta; entrega con foto.



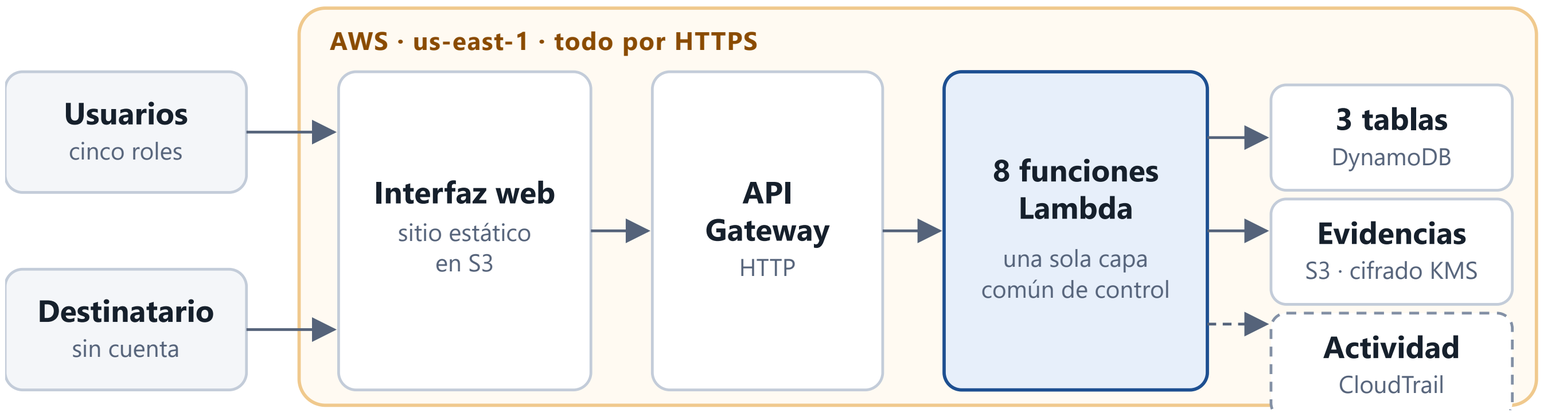
Consulta pública
El destinatario, sin cuenta, ca



Bitácora de auditoría
La cadena se recalcula y verifica; solo el auditor la lee.

También: detalle de cada envío con su histórico, registro masivo desde CSV con vista previa, guías imprimibles con código de barras Code 128, exportación de la operación, catálogos de tiendas, clientes y transportistas, y administración de cuentas y roles por empresa. Interfaz web *mobile-first*, usable desde 360 px, y un segundo cliente en Flet para escritorio, web y Android.

5 Arquitectura sin servidor en AWS



`auth`	identidad y sesiones revocables
`shipments`	registro, asignación y guías
`tracking`	puntos de control y rutas
`evidence`	enlaces prefirmados
`public`	consulta sin autenticación
`audit`	bitácora y verificador
`masters`	tiendas, clientes y catálogos
`dashboard`	indicadores de operación

6 Resultados y pruebas

Pruebas automatizadas
Unitarias y de extremo a extremo; sin Docker ni credenciales.

```
327 passed, 5 skipped · 0 fallos
```

Despliegue verificado en AWS
26/09/2026, código de salida 0; 16/10/2026, con sitio HTTPS y modo ruta: todo verificado.

Auditoría independiente
Un programa aparte evaluó 11 controles: 10 conformes, 1 desviado, 0 sin ejecutar.

Hallazgo principal, corregido
El secreto de firma de sesiones estuvo publicado 27 minutos: se rotó, se redesplegaron las ocho funciones y hoy lo vigila el control C-09.

7 Normativa

MARCO	CÓMO SE ATIENDE
Ley 1581 de 2012	Minimización, cifrado, acceso por rol; datos sintéticos
ISO/IEC 27001:2022	Llave propia con rotación; versionado
CIS AWS	Registro con validación de integridad
OWASP A01:2021	Identificadores aleatorios; 404 entre empresas
NIST SP 800-92	Bitácora: actor, acción, recurso, momento
Well-Architected	Mínimo privilegio: no se cumple, el laboratorio no permite un rol por función

8 Tecnologías

NUBE
Lambda · API Gateway · DynamoDB · S3 · KMS · CloudTrail

SERVICIOS
Python · FastAPI · boto3 · JWT · PBKDF2

INTERFAZ
React · TypeScript · Vite · Leaflet · OpenStreetMap

ENTORNO Y CALIDAD
Docker Compose · nginx · MinIO · pytest

9 Conclusiones

- Los **nueve requisitos** se cumplen y pueden comprobarse.
- **Tres verificaciones** independientes coinciden: pruebas, despliegue y auditoría.
- Tres riesgos se materializaron; los tres se gestionaron.

Siguiente paso: un rol de ejecución por función y validar con una empresa real.

Limitaciones declaradas: sin usuarios reales; mínimo privilegio incumplido; integridad de la bitácora por detección, no por prevención, frente a quien administra la cuenta.